

Conntact Security

1. SQL Injection (SQLi)

- **Skenario:** Memasukkan kode SQL (misal ' `OR 1=1`) ke input form untuk memanipulasi/menghapus database.
- **Mitigasi :**
Backend (Node.js) **menerapkan *Prepared Statements (Query Berparameter)***. Sistem database akan memisahkan perintah SQL dari data input pengguna menggunakan penanda (*placeholder* seperti `?`). Ini memastikan input pengguna diperlakukan murni sebagai data teks, sehingga perintah berbahaya yang disisipkan tidak akan pernah dieksekusi oleh database .

2. Stored XSS (Cross-Site Scripting)

- **Skenario:** Menyisipkan script (`<script>`) ke pesan. Script tereksekusi saat Admin membuka pesan, berpotensi mencuri sesi login.
- **Mitigasi:**
 - **Di Sisi Server (Backend):** Lakukan **Sanitasi Input** sebelum data disimpan ke database. Gunakan library pembersih sebelum disimpan. `const pesanAman = sanitize(req.body.pesan);` (Otomatis membuang tag `<script>`)
 - **Di Sisi Tampilan (Frontend):** Lakukan **Output Escaping** saat menampilkan data pesan di dasbor admin. Pastikan browser merender data tersebut hanya sebagai teks biasa, bukan sebagai kode yang dapat dijalankan .

3. Spam & DDoS

- **Skenario:** Bot membanjiri API dengan ribuan pesan sampah, membuat server *down* dan email Admin penuh spam.
- **Mitigasi:**
 - **Rate Limiting (Sisi Server):** Batasi frekuensi permintaan API dari satu alamat IP dalam periode waktu tertentu (misalnya: `const batasi = rateLimit({ max: 5 });` (Satu orang cuma boleh kirim 5 kali per jam) untuk mencegah pembanjiran *request*.
 - **Validasi Turing (Sisi Klien):** Integrasikan mekanisme **CAPTCHA** pada formulir sebelum tombol kirim aktif, untuk memvalidasi bahwa pengirim adalah manusia .

5. Man-in-the-Middle (MITM) (**Penyadapan**)

- **Skenario:** Penyadapan data (nama/pesan) di jaringan publik (WiFi kafe) karena data dikirim sebagai teks polos.
- **Mitigasi:** Terapkan protokol **HTTPS (SSL/TLS)** secara penuh pada lingkungan produksi. Ini menciptakan saluran terenkripsi (*encrypted tunnel*) yang mencegah pihak ketiga menyadap atau membaca isi pesan pada jaringan publik .

6. Email Header Injection

- **Skenario:** Di kolom subjek, hacker mengetik: `Halo \n BCC: korban@lain.com`. Kode `\n` (enter) membuat server email tertipu dan mengirim ke korban lain.
- **Mitigasi :** Lakukan pembersihan karakter kontrol (*Header Stripping*). Pastikan input pada kolom "Subjek" atau data "Header" lainnya tidak mengandung karakter baris baru (`\n` atau `\r`). Gunakan pustaka email yang aman (seperti *Nodemailer*) yang memvalidasi integritas header secara otomatis .